ROTEIRO DE ESTUDOS · WINDOWS SERVER 2025 · MÓDULO 08

Segurança e hardening

Modelo de acesso privilegiado, proteção do AD, Windows LAPS, Credential Guard, linha de base com OSConfig, Defender, App Control, firewall, endurecimento de protocolos e auditoria para detecção

Nível	Avançado
Carga sugerida	2 semanas (16–20 h)
Pré-requisitos	Módulos 03, 04 e 06
Relação com AZ-802	Domínio "Secure Windows Server infrastructure" (10–15%): SO e AD DS; base para o domínio de monitoramento

Objetivos do módulo

- Entender como ataques ao AD costumam acontecer e por que credenciais privilegiadas são o alvo.
- Aplicar o modelo de acesso privilegiado da Microsoft (planos de controle, gerência e dados) e o conceito de estação de trabalho privilegiada.
- Proteger contas e grupos sensíveis: Protected Users, contas de administração separadas, delegação mínima.
- Implantar o Windows LAPS com as novidades do 2025.
- Habilitar e verificar Credential Guard, VBS e a linha de base de segurança via OSConfig.
- Configurar Defender Antivirus, App Control, proteção contra exploits e firewall.
- Endurecer SMB, LDAP, NTLM e Kerberos e auditar antes de bloquear.
- Configurar a política de auditoria avançada e conhecer os Event IDs mais importantes para detecção.

1. Como o AD costuma ser atacado

Um ataque típico a uma rede Windows não começa no controlador de domínio. Ele começa numa estação comprometida (phishing, vulnerabilidade), e o atacante procura **credenciais** na memória ou no disco para se mover lateralmente até chegar a uma conta com privilégio no domínio. Técnicas clássicas que você precisa conhecer como defensor:

Técnica	Ideia	Defesas principais
Roubo de credenciais da memória (LSASS)	Extrair hashes e tickets de quem fez logon na máquina	Credential Guard, Protected Users, não logar com admin de domínio em estações
Pass-the-Hash / Pass-the-Ticket	Reutilizar hash NTLM ou ticket Kerberos sem saber a senha	LAPS, contas separadas por nível, restrição de NTLM
Kerberoasting	Pedir tickets de serviço e quebrar a senha da conta de serviço offline	gMSA/dMSA (senhas longas e aleatórias), AES em vez de RC4, monitorar evento 4769

Técnica	Ideia	Defesas principais
Password spraying e força bruta	Testar senhas comuns em muitas contas	Senhas fortes, Entra Password Protection, bloqueio, limitador de autenticação do SMB
NTLM relay	Retransmitir uma autenticação NTLM para outro serviço	Assinatura SMB e LDAP, channel binding, EPA, bloqueio de NTLM
DCSync	Fingir ser um DC e pedir a replicação de hashes	Ninguém além dos DCs com direitos de replicação; monitorar evento 4662
Golden Ticket	Forjar TGTs com o hash da conta krbtgt	Proteger nível 0; trocar a senha do krbtgt periodicamente e após incidente

SEGURANÇA

A regra de ouro: **uma credencial de nível alto nunca deve ser digitada ou usada numa máquina de nível mais baixo**. Um administrador de domínio que faz logon numa estação comprometida entrega o domínio ao atacante.

2. Modelo de acesso privilegiado

A Microsoft substituiu o antigo "modelo de camadas" (tier 0/1/2) pelo **Enterprise Access Model**, que separa:

- **Plano de controle**: o que controla identidades e permissões: AD DS, DCs, Entra ID, PKI, sistemas de backup e de gerência dos DCs, hosts de virtualização que hospedam DCs. É o antigo nível 0.
- **Plano de gerência**: ferramentas e contas que administram servidores e aplicações (antigo nível 1).
- **Plano de dados e cargas de trabalho**: aplicações, dados e estações dos usuários (antigo nível 2).
- **Acesso de usuários e de aplicações**: os caminhos por onde pessoas e apps chegam aos recursos.

Práticas que derivam dele:

- **Contas separadas**: `ana.souza` para e-mail e navegação; `adm-ana` para administração de servidores; e uma conta de nível 0 apenas para quem realmente administra o AD.
- **PAW (Privileged Access Workstation)**: estação dedicada e endurecida para administração, sem e-mail e navegação.
- **Menor privilégio e Just-Enough/Just-In-Time**: JEA (Módulo 02), delegação em OUs (Módulo 03), associação temporária a grupos.
- **Grupos privilegiados quase vazios**: Enterprise Admins e Schema Admins vazios no dia a dia; Domain Admins com o mínimo de pessoas; nada de contas de serviço nesses grupos.

2.1 Proteções nativas para contas sensíveis

- **Protected Users**: membros não usam NTLM, não usam DES ou RC4 no Kerberos, não podem ser delegados, não têm credenciais armazenadas em cache e recebem TGT com validade de 4 horas. Coloque nele as contas administrativas humanas (não contas de serviço e não contas de computador) e teste antes.
- **"A conta é confidencial e não pode ser delegada"**: marque em todas as contas administrativas.

- **Authentication Policies e Silos**: restringem de quais máquinas uma conta privilegiada pode fazer logon.
- **AdminSDHolder/SDProp**: a cada 60 minutos, as permissões de membros de grupos protegidos são sobrescritas pelo modelo do AdminSDHolder. Alterações nesse objeto são um indicador clássico de persistência.

```
Add-ADGroupMember "Protected Users" -Members adm-ana
Set-ADUser adm-ana -AccountNotDelegated $true
Get-ADGroupMember "Domain Admins" -Recursive | Select-Object Name, objectClass
Get-ADUser -Filter {AdminCount -eq 1} -Properties AdminCount | Select-Object Name
Get-ADUser -Filter {ServicePrincipalName -like "*"} -Properties ServicePrincipalName |
    Select-Object Name, ServicePrincipalName          # contas sujeitas a Kerberoasting
```

2.2 A conta krbtgt

O hash da conta `krbtgt` assina todos os TGTs do domínio. Troque a senha dela periodicamente e **sempre após um incidente**, em duas etapas separadas pelo tempo de replicação e pela validade máxima dos tickets, porque o AD guarda a senha atual e a anterior. A Microsoft disponibiliza um script oficial (New-KrbtgtKeys.ps1) que faz o processo com verificações.

3. Windows LAPS

O Windows LAPS gera uma senha única e aleatória para a conta de administrador local de cada computador, troca periodicamente e guarda no AD (ou no Entra ID), com leitura controlada por permissão. Acaba com a mesma senha de administrador local em todas as máquinas, que é o que permite o movimento lateral por Pass-the-Hash.

```
# 1) Estender o esquema (uma vez) e dar permissão aos computadores de gravar a própria senha
Update-LapsADSchema
Set-LapsADComputerSelfPermission -Identity "OU=Servidores,DC=corp,DC=lab,DC=internal"
Set-LapsADComputerSelfPermission -Identity "OU=Computadores,DC=corp,DC=lab,DC=internal"

# 2) Quem pode ler as senhas (apenas o grupo de suporte autorizado)
Set-LapsADReadPasswordPermission -Identity "OU=Computadores,DC=corp,DC=lab,DC=internal"
    ↪ -AllowedPrincipals "CORP\GG-Suporte-N2"

# 3) GPO: Configuração do Computador > Modelos Administrativos > Sistema > LAPS
#    - Configure password backup directory = Active Directory
#    - Password Settings (complexidade, tamanho, idade)
#    - Enable password encryption (recomendado; exige nível funcional 2016+)

# 4) Uso
Invoke-LapsPolicyProcessing                          # no cliente: força o ciclo
Get-LapsADPassword -Identity CLI01 -AsPlainText      # ler a senha (com permissão)
Reset-LapsPassword                                   # no cliente: força nova senha
```

Novidades do LAPS no Windows Server 2025:

- **Gerenciamento automático de conta**: cria e gerencia a conta local, com nome personalizado ou aleatório, e pode habilitá-la ou desabilitá-la.
- **Detecção de reversão de imagem**: o atributo `msLAPS-CurrentPasswordVersion` detecta quando uma VM volta a um snapshot antigo e troca a senha imediatamente (exige rodar a versão atual de `Update-LapsADSchema`).
- **Frases-senha (passphrases)** e um novo nível de complexidade (5) que evita caracteres confusos como 1/l/I e 0/O.
- **Ações pós-autenticação**: após o uso da senha, redefinir, fazer logoff e encerrar os processos que ainda rodam com a conta.

4. Proteções baseadas em virtualização

- **VBS (Virtualization-based Security)**: usa o hipervisor para criar uma região de memória isolada do próprio sistema operacional.
- **Integridade de memória (HVCI)**: só código de kernel assinado e verificado roda; dificulta drivers maliciosos.
- **Credential Guard**: isola os segredos do LSA (hashes NTLM e TGTs) no ambiente VBS, impedindo que ferramentas de dump de memória os leiam. **No Windows Server 2025 ele é habilitado por padrão** em máquinas que atendem aos requisitos. A documentação indica que ele não deve ser usado em controladores de domínio, onde não traz proteção adicional.
- **Proteção de chaves por VBS e enclaves VBS** (novos no 2025): permitem que aplicações protejam chaves e segredos fora do alcance até de administradores.
- **Remote Credential Guard / Restricted Admin no RDP**: evitam deixar credenciais reutilizáveis no servidor de destino de uma sessão RDP.

```
Get-CimInstance -ClassName Win32_DeviceGuard -Namespace root\Microsoft\Windows\DeviceGuard |
    Select-Object VirtualizationBasedSecurityStatus, SecurityServicesConfigured,
        ↪ SecurityServicesRunning
# SecurityServicesRunning: 1 = Credential Guard, 2 = HVCI
mstsc /remoteGuard        # RDP com Remote Credential Guard
```

5. Linha de base de segurança com OSConfig

O **OSConfig** é o novo mecanismo do Windows Server 2025 para aplicar a linha de base de segurança recomendada pela Microsoft (mais de 350 configurações), por função do servidor, com **controle de desvios** (drift control): se alguém alterar uma configuração, ela volta ao valor desejado no próximo ciclo.

```
Install-Module -Name Microsoft.OSConfig -Scope AllUsers -Force
Get-Module -ListAvailable -Name Microsoft.OSConfig

# Aplicar conforme a função (reinicie depois)
Set-OSConfigDesiredConfiguration -Scenario SecurityBaseline/WindowsServer/2025/DomainController
    ↪ -Default
Set-OSConfigDesiredConfiguration -Scenario SecurityBaseline/WindowsServer/2025/MemberServer
    ↪ -Default
Set-OSConfigDesiredConfiguration -Scenario SecurityBaseline/WindowsServer/2025/WorkgroupMember
    ↪ -Default

# Cenários complementares
Set-OSConfigDesiredConfiguration -Scenario Defender/Antivirus/WindowsServer/2025 -Default
Set-OSConfigDesiredConfiguration -Scenario SecuredCore -Default

# Consultar ou personalizar uma configuração específica
Get-OSConfigDesiredConfiguration -Scenario SecurityBaseline/WindowsServer/2025/MemberServer
    ↪ -Setting AuditDetailedFileShare
Set-OSConfigDesiredConfiguration -Scenario SecurityBaseline/WindowsServer/2025/MemberServer
    ↪ -Setting AuditDetailedFileShare -Value 3
```

ATENÇÃO

Pontos de atenção da documentação oficial

- É necessário **reiniciar** depois de aplicar ou remover a linha de base.
- Em servidores membros e de grupo de trabalho, a senha do administrador local precisa ser trocada depois (complexa e com no mínimo 14 caracteres).
- A linha de base desativa a cópia de arquivos e área de transferência via RDP e pode bloquear conexões antigas (TLS abaixo de 1.2, SMB abaixo de 3.0, algumas configurações de Samba no Linux).
- Não gerencie as mesmas configurações por duas ferramentas ao mesmo tempo (por exemplo, OSConfig e GPO com valores diferentes), senão elas ficam "brigando".
- Remover a linha de base não garante voltar aos valores anteriores. Teste em laboratório.

Em ambientes com muitos servidores, a conformidade é acompanhada pelo **Azure Policy / Machine Configuration** em servidores com Azure Arc (Módulo 11). Em domínios, a alternativa clássica são as GPOs do **Security Compliance Toolkit** (Módulo 04).

6. Defender, App Control e proteção contra exploits

6.1 Microsoft Defender Antivirus

Vem embutido no Windows Server. Em servidores, o Defender aplica automaticamente exclusões para as funções instaladas.

```
Get-MpComputerStatus | Select-Object AMServiceEnabled, RealTimeProtectionEnabled,
    ↪ AntivirusSignatureLastUpdated, IsTamperProtected
Update-MpSignature
Start-MpScan -ScanType QuickScan
Get-MpThreatDetection
Set-MpPreference -AttackSurfaceReductionRules_Ids <GUID-da-regra>
    ↪ -AttackSurfaceReductionRules_Actions AuditMode
```

O **Microsoft Defender for Servers** (plano do Defender for Cloud, Módulo 11) adiciona EDR (Defender for Endpoint) e avaliação de vulnerabilidades e, no plano 2, acesso JIT a VMs e monitoramento de integridade de arquivos.

6.2 Controle de aplicativos

- **App Control for Business** (antigo WDAC): lista de permissões no nível do kernel; só executa o que a política autoriza. É a recomendação atual para servidores de função fixa.
- **AppLocker**: regras por usuário/grupo, mais simples, mas considerado recurso de defesa em profundidade, não um limite de segurança.
- Comece sempre em **modo de auditoria** e analise os eventos antes de impor.

6.3 Proteção contra exploits e SmartScreen

```
Get-ProcessMitigation -System
Set-ProcessMitigation -System -Enable DEP, SEHOP, ForceRelocateImages
```

O **Microsoft Defender SmartScreen** avalia a reputação de downloads e executáveis; em servidores com Desktop Experience pode ser configurado por GPO.

7. Firewall do Windows

Três perfis: **Domínio** (rede onde o DC é alcançável), **Privado** e **Público**. A boa prática em servidores é: firewall ligado nos três perfis, entrada bloqueada por padrão e regras explícitas, inclusive restringindo **de onde** se pode administrar.

```
Get-NetFirewallProfile | Select-Object Name, Enabled, DefaultInboundAction, LogAllowed, LogBlocked
Set-NetFirewallProfile -All -Enabled True -DefaultInboundAction Block -LogBlocked True `
    -LogFileName %systemroot%\System32\LogFiles\Firewall\pfirewall.log -LogMaxSizeKilobytes 16384

# RDP e WinRM só a partir da sub-rede de administração
New-NetFirewallRule -DisplayName "RDP - so admin" -Direction Inbound -Protocol TCP -LocalPort
    ↪ 3389 `
    -RemoteAddress 10.10.99.0/24 -Action Allow -Profile Domain
New-NetFirewallRule -DisplayName "WinRM - so admin" -Direction Inbound -Protocol TCP -LocalPort
    ↪ 5985 `
    -RemoteAddress 10.10.99.0/24 -Action Allow -Profile Domain
```

As **regras de segurança de conexão** usam IPsec para autenticar e opcionalmente criptografar o tráfego entre máquinas (isolamento de servidores e de domínio). No Windows Server 2025, conexões IPsec autenticadas por certificado de máquina passaram a usar **IKEv2 e IKEv1** como protocolos de troca de chaves padrão.

8. Endurecimento de protocolos

Protocolo	Situação no 2025	O que fazer
SMB	Assinatura exigida em conexões de saída; SMB1 ausente; limitador de autenticação ativo	Auditar dispositivos sem suporte, exigir criptografia em dados sensíveis (Módulo 06)
LDAP	TLS 1.3; assinatura exigida em implantações novas; eventos de auditoria de channel binding (3074/3075)	Monitorar o evento 2889 (binds sem assinatura), exigir assinatura e channel binding
NTLM	NTLMv1 removido; NTLM como um todo em processo de descontinuação	Auditar uso (políticas "Network security: Restrict NTLM"), migrar apps para Kerberos, bloquear NTLM no SMB onde possível
Kerberos	DES removido; KDC não emite TGT com RC4	Encontrar contas que ainda dependem de RC4 (`msDS-SupportedEncryptionTypes`), configurar tipos de criptografia por GPO
TLS	1.0 e 1.1 descontinuados; certificados RSA de servidor precisam de chave de pelo menos 2048 bits	Desabilitar protocolos antigos e revisar certificados
VPN (RRAS)	Instalações novas não aceitam PPTP e L2TP por padrão	Usar IKEv2 ou SSTP

DICA

Siga sempre a ordem **auditar → corrigir dependências → impor**. Bloquear NTLM ou exigir assinatura LDAP sem auditar antes derruba aplicações legadas. A página oficial "Latest Windows hardening guidance and key dates" lista as fases de endurecimento que a Microsoft impõe via atualizações mensais.

9. Endurecimento de controladores de domínio

- Instale em **Server Core**, sem funções extras além de AD DS e DNS (e, no lab, DHCP).
- Nada de navegação, e-mail ou software de terceiros desnecessário nos DCs.
- **Restrinja o logon**: apenas administradores de nível 0 podem fazer logon local ou via RDP nos DCs; negue esse direito aos demais grupos administrativos por GPO.
- **Microsoft Entra Password Protection para AD DS**: agente nos DCs e serviço de proxy que bloqueiam senhas da lista global de senhas fracas e de uma lista personalizada (nome da empresa, cidade), mesmo para contas apenas locais no AD.
- **Backup do estado do sistema** testado e armazenado fora do domínio (Módulo 09); BitLocker nos volumes; segurança física.
- Aplique a linha de base de DC via OSConfig ou SCT e monitore desvios.

10. Auditoria para detecção (Blue Team)

10.1 Política de auditoria avançada

Configure por GPO em `Configuração do Computador > Políticas > Configurações do Windows > Configurações de Segurança > Configuração Avançada de Política de Auditoria`, e habilite **"Forçar configurações de subcategoria de política de auditoria"** para que ela tenha precedência sobre a política básica.

```
auditpol /get /category:*
auditpol /set /subcategory:"Logon" /success:enable /failure:enable
auditpol /set /subcategory:"Process Creation" /success:enable
```

Habilite também a inclusão da linha de comando nos eventos de criação de processo (GPO "Incluir linha de comando nos eventos de criação de processo") e o log de blocos de script do PowerShell.

10.2 Event IDs que todo analista precisa conhecer

ID	Log	Significado	Por que importa
4624 / 4625	Security	Logon com sucesso / falha	Tipo de logon (2 interativo, 3 rede, 10 RDP); força bruta e spraying
4648	Security	Logon com credenciais explícitas	Uso de `runas` e movimento lateral
4672	Security	Privilégios especiais atribuídos ao logon	Logons administrativos
4688	Security	Processo criado	Execução de ferramentas; com linha de comando habilitada
4697 / 7045	Security / System	Serviço instalado	Persistência e execução remota (PsExec e similares)
4698	Security	Tarefa agendada criada	Persistência
4720 / 4726	Security	Conta de usuário criada / excluída	Contas indevidas
4728 / 4732 / 4756	Security	Membro adicionado a grupo global / local / universal	Elevação de privilégio (ex.: Domain Admins)

ID	Log	Significado	Por que importa
4740	Security	Conta bloqueada	Força bruta; registrado no PDC Emulator
4768 / 4769 / 4771	Security	TGT pedido / ticket de serviço pedido / pré-autenticação Kerberos falhou	Kerberoasting (4769 com criptografia RC4, tipo 0x17) e ataques de senha
4776	Security	Validação de credencial NTLM	Uso de NTLM, spraying
4662	Security	Operação em objeto do diretório	DCSync (direitos de replicação usados por quem não é DC)
5136	Security	Objeto do diretório modificado	Alterações em GPOs, AdminSDHolder, ACLs
4719 / 1102	Security	Política de auditoria alterada / log de segurança limpo	Atacante encobrindo rastros
4104	PowerShell/Operational	Bloco de script do PowerShell	Scripts maliciosos, inclusive ofuscados

```
# Falhas de logon das últimas 24 h, agrupadas por conta e origem
Get-WinEvent -FilterHashtable @{ LogName='Security'; Id=4625; StartTime=(Get-Date).AddDays(-1) } |
    ForEach-Object { $x = [xml]$_.ToXml()
        [pscustomobject]@{
            Conta  = ($x.Event.EventData.Data | Where-Object Name -eq 'TargetUserName').'#text'
            Origem = ($x.Event.EventData.Data | Where-Object Name -eq 'IpAddress').'#text'
        } } | Group-Object Conta, Origem | Sort-Object Count -Descending | Select-Object -First 10
```

O **Sysmon** (Sysinternals, gratuito e oficial da Microsoft) complementa o log de segurança com eventos detalhados de processos, conexões de rede, criação de arquivos e carregamento de drivers. No Módulo 10 você centraliza esses logs com o Windows Event Forwarding, e no Módulo 11 envia ao Azure Monitor.

LABORATÓRIO

Laboratório 8.1: endurecimento do lab

- Crie contas administrativas separadas, coloque-as em Protected Users e marque como não delegáveis.
- Implante o Windows LAPS para as OUs Servidores e Computadores; leia a senha do CLI01 com o grupo autorizado e tente com um usuário comum.
- Verifique se o Credential Guard está ativo no SRV01 e no CLI01.
- Aplique a linha de base do OSConfig no SRV01 (MemberServer) após um checkpoint. Liste o que quebrou e o que você precisou ajustar.
- Restrinja RDP e WinRM nos servidores a uma sub-rede de administração.

LABORATÓRIO

Laboratório 8.2: detecção

- Configure a auditoria avançada por GPO (logon, criação de processo com linha de comando, gerenciamento de contas e de grupos, serviços de diretório).
- Gere eventos de propósito: senhas erradas em várias contas, adição de um usuário a Domain Admins, criação de serviço, limpeza do log.
- Escreva consultas `Get-WinEvent` que encontrem cada um deles e documente no GitHub como um "mini playbook" de detecção.
- Instale o Sysmon com uma configuração pública conhecida e compare o que ele registra com o 4688.

Checklist de revisão

- Descreva os planos de controle, gerência e dados. O que entra no plano de controle?
- O que o grupo Protected Users muda no comportamento de uma conta?
- Por que o LAPS reduz o risco de Pass-the-Hash? Cite duas novidades do 2025.
- O que o Credential Guard protege? Onde ele não deve ser usado?
- Quais cuidados antes de aplicar a linha de base do OSConfig?
- Por que auditar antes de bloquear NTLM ou exigir assinatura LDAP?
- Quais Event IDs indicam Kerberoasting, DCSync, alteração de grupos privilegiados e limpeza de log?

Referências oficiais

- Modelo de acesso privilegiado (Enterprise Access Model)
  https://learn.microsoft.com/en-us/security/privileged-access-workstations/privileged-access-access-model
- Boas práticas para proteger o Active Directory
  https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/plan/security-best-practices/best-practices-for-securing-active-directory
- Grupo de segurança Protected Users
  https://learn.microsoft.com/en-us/windows-server/security/credentials-protection-and-management/protected-users-security-group
- O que é o Windows LAPS
  https://learn.microsoft.com/en-us/windows-server/identity/laps/laps-overview
- Configurar o Credential Guard
  https://learn.microsoft.com/en-us/windows/security/identity-protection/credential-guard/configure
- Visão geral do OSConfig
  https://learn.microsoft.com/en-us/windows-server/security/osconfig/osconfig-overview
- Implantar linhas de base de segurança com OSConfig
  https://learn.microsoft.com/en-us/windows-server/security/osconfig/osconfig-how-to-configure-security-baselines
- Recomendações de política de auditoria
  https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/plan/security-best-practices/audit-policy-recommendations
- Orientações de hardening do Windows e datas-chave
  https://support.microsoft.com/en-us/servicing/os/windows/2024/02/latest-windows-hardening-guidance-and-key-dates
- Assinatura LDAP no AD DS
  https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/ldap-signing
- Sysmon (Sysinternals)
  https://learn.microsoft.com/en-us/sysinternals/downloads/sysmon